

Acceptable Use Policy

NOVAtech Inc. | Simulated for demonstration

Document	Acceptable Use Policy
Version	1.0
Owner	Head of Security
Approved by	Chief Technology Officer
Effective date	2026-08-03
Next review	Annually
Acknowledgement	Signed at onboarding and re-acknowledged annually
Framework alignment	ISO/IEC 27001:2022 A.5.10 (Acceptable use of information and other associated assets); A.6.3

1. PURPOSE

This policy defines how NOVAtech personnel may use company systems, devices, accounts, and data. It exists to protect customers, colleagues, and the company from avoidable security and legal risk. It is written to be readable and actionable rather than exhaustive: when a situation is not covered here, the expectation is that personnel apply good judgment and ask the security team.

2. SCOPE

Applies to all employees, contractors, and third parties using NOVAtech devices, accounts, networks, or data, whether on company premises, at home, or travelling.

3. GENERAL USE

- **Business purpose:** Company systems are provided for business use. Limited personal use is permitted where it does not affect security, productivity, system performance, or the company's reputation.
- **No expectation of privacy on company systems:** NOVAtech may monitor, log, and review activity on company systems and networks as permitted by applicable law, for security, operational, and compliance purposes.
- **Applicable law and policy:** Use of company systems must comply with applicable law and all NOVAtech policies, including this policy, the Information Security Policy, and the Access Control Policy.

4. ACCOUNT AND CREDENTIAL USE

- **Credentials are personal:** Never share passwords, MFA codes, or authentication devices with anyone, including colleagues, managers, or IT staff. NOVAtech staff will never ask for your password.
- **MFA prompts:** Never approve an MFA prompt you did not initiate. An unexpected prompt means someone has your password - deny it and report it immediately.
- **Password managers:** Use the company-provided password manager for work credentials. Do not store work credentials in browsers on personal devices, in documents, or in chat messages.
- **Reuse:** Do not reuse your work password on any other service, personal or professional.

5. DATA HANDLING

- **Classification awareness:** Handle information according to its classification. Restricted and Confidential data have specific handling requirements defined in the Data Classification Standard.
- **Approved storage only:** Store company and customer data only in approved systems. Do not move company data to personal cloud accounts, personal email, personal devices, or removable media.
- **Public AI and external tools:** Do not paste Confidential or Restricted information (including customer data, source code, credentials, or internal documents) into public AI assistants, translation services, or other external tools. Approved internal tooling is available; ask the security team if unsure.

- **Sharing externally:** Share company information externally only with a business need and appropriate approval. Verify recipients before sending; check that link-sharing permissions are restricted rather than open.
- **Bulk exports:** Bulk export of customer data from the CRM or platform requires business justification and is monitored. Routine work does not require bulk exports.

6. SOFTWARE AND SERVICES

- **Approved software:** Install only software from the approved software list or through the company software portal. Requests for new tools go through IT.
- **Shadow IT:** Do not sign up for external SaaS services using your work email or for work purposes without approval. Unapproved services that hold company or customer data are prohibited - this includes free tiers and trials.
- **Browser extensions:** Install browser extensions only from the approved list. Extensions can read everything you see in the browser.

7. DEVICES

- **Company devices:** Company laptops must run company MDM, endpoint detection, and full-disk encryption at all times. Do not disable, bypass, or tamper with security agents.
- **Physical security:** Lock your screen when stepping away. Do not leave devices unattended in public spaces or visible in vehicles.
- **Loss or theft:** Report loss or theft of any device holding company data or credentials within 4 hours of discovery, at any hour.
- **Personal devices:** Accessing company email or systems from a personal device requires enrolment in mobile device management. Personal devices must have a screen lock and current OS updates.

8. EMAIL, MESSAGING, AND PHISHING

- **Report suspicious messages:** Use the report-phishing function for any suspicious email. Reporting a legitimate message by mistake costs nothing; not reporting a real one can cost a great deal.
- **Verify unusual requests:** Verify any unexpected request involving payments, credential entry, gift cards, or urgency through a second channel - call the person, do not reply to the message.
- **No retaliation:** If you clicked something or entered credentials, report it immediately. Prompt reporting limits harm and is always the right call. Personnel who report their own mistakes in good faith will not face disciplinary action for the mistake itself.

9. REMOTE WORK

- **Networks:** Avoid conducting sensitive work on untrusted public Wi-Fi. Use the corporate VPN when accessing internal systems from untrusted networks.
- **Workspace:** Be aware of who can see your screen or overhear calls in shared and public spaces. Use privacy screens when working in public.
- **Household:** Company devices are for the employee's use only. Family members must not use company devices or accounts.

10. PROHIBITED ACTIVITIES

The following are prohibited on company systems or using company accounts:

- Attempting to circumvent security controls, monitoring, or access restrictions
- Accessing data or systems you are not authorized to access, including out of curiosity
- Sharing, selling, or exfiltrating company or customer data
- Installing or running unauthorized security tools, network scanners, or credential-testing tools against company or third-party systems
- Using company systems for illegal activity, harassment, or activity that damages the company's reputation
- Connecting unauthorized devices to the corporate network or production environments

11. REPORTING

Report suspected incidents, security weaknesses, lost devices, or policy concerns through the security channel in Slack, by emailing the security team, or to any manager. When in doubt, report. Reports are treated confidentially to the extent possible.

12. COMPLIANCE AND ENFORCEMENT

Violations of this policy may result in disciplinary action up to and including termination of employment or contract, and where applicable, referral to law enforcement. Enforcement is proportionate: honest mistakes reported promptly are handled as learning opportunities; deliberate circumvention of controls is not.

13. ACKNOWLEDGEMENT

All personnel acknowledge this policy at onboarding and annually thereafter. Acknowledgement records are retained as audit evidence and reported as part of the awareness training metrics.

14. CHANGE HISTORY

v1.0 (issued 2026-08-03): initial policy covering credential use, data handling, approved software and shadow IT, device requirements, phishing reporting, remote work, and prohibited activities.